AUTONOMOUS AI AGENT GOVERNANCE & CONTINUOUS COMPLIANCE

Extending Drata's Trust Platform to Autonomous Coding Agents

Bridging the critical compliance blind spot created by Cursor, Claude Code, and autonomous developer swarms with in-process, sub-35-microsecond deterministic evidence generation.

Zero-Egress Attestation

Guaranteed replacement of HIPAA PHI and production credentials before reaching cloud LLMs.

Deterministic Tool Invariants

Sub-35µs AST execution firewall blocking destructive commands (DROP TABLE, rm -rf).

Turnkey Drata Ingestion

Automated export of SHA-256 Merkle compliance dossiers mapped directly to SOC 2 & HIPAA controls.

The Enterprise Crisis: Autonomous Agents in Regulated Workspaces

Drata's customers are rapidly adopting AI coding tools (Cursor, Claude Code, Windsurf, Copilot). However, security teams and auditors face three critical unmonitored failure modes.

FAILURE MODE 1

Unchecked Data & PII Egress

Developers inadvertently transmit real customer PII, patient health information (PHI), and API secrets directly into Anthropic/OpenAI prompt contexts.

Auditor Impact: Direct violation of SOC 2 CC6.7 and HIPAA § 164.312 confidentiality mandates.

FAILURE MODE 2

Untracked Tool & CLI Exploitation

Agents executing terminal scripts or MCP tools can execute destructive commands due to hallucination or prompt injection (e.g., dropping database tables, deleting branches).

Auditor Impact: Failure of SOC 2 CC6.6 boundary protection and change management controls.

FAILURE MODE 3

Ephemeral Non-Human Identity

Agents operate with broad user permissions but lack persistent identity, signed capability scopes, or tamper-evident execution ledgers.

Auditor Impact: Lack of accountability and attribution under SOC 2 CC6.1 logical access controls.

What Bartholomew Offers Drata: The In-Process Runtime Layer

Bartholomew provides Drata with the industry's first deterministic Agentic Runtime Protection (ARP) integration, generating continuous compliance evidence right on developer endpoints.

ENDPOINT TELEMETRY

In-Process Tokenization Vault

Intercepts prompts in local RAM (<35µs). Replaces credentials and PII with format-preserving surrogates before prompts leave the IDE.

- ✓ Zero data leaks to third-party LLMs
- ✓ JIT local detokenization for test runs
- ✓ Continuous evidence of zero secret egress

EXECUTION GATE

Polyglot AST Invariant Shield

Wraps terminal executions and MCP server stdio pipes. Destructive actions are blocked fail-closed before execution reaches the OS kernel.

- ✓ Blocks DROP TABLE, rm -rf, reverse shells
- ✓ Ephemeral HMAC capability passkeys
- ✓ Atomic SQLite WAL-mode replay defense

DRATA EVIDENCE STREAM

Automated Merkle Dossier Export

One-click or CLI export (`mcp-shield export-compliance`) producing structured, cryptographic audit dossiers mapped to Drata controls.

- ✓ SHA-256 Merkle root verification
- ✓ Tamper-evident ledger of all tool actions
- ✓ Auto-synced to Drata Evidence Locker

Seamless Mapping into Drata Controls

Bartholomew attestation dossiers plug directly into Drata's standard SOC 2 and HIPAA automated tests.

Drata Standard Control	Compliance Objective	Bartholomew Verification Mechanism	Auditor Evidence Format
SOC 2 CC6.1	Logical Access Control & Least Privilege	Signed ephemeral HMAC-SHA256 capability passkeys scoping agent execution paths.	`Cryptographic Passkey Log (.btp/audit.log)`
SOC 2 CC6.6	Boundary Protection & Invariant Gating	Sub-35µs polyglot AST execution firewall gating shell and MCP database tool mutations.	`Fail-Closed Interception Ledger`
SOC 2 CC6.7	Data Transmission Confidentiality	Format-preserving surrogate tokenization preventing credentials & PII from leaving memory.	`Zero-Egress Surrogacy Proofs`
HIPAA § 164.312(a)(1)	Unique Non-Human Identity & Access Control	Single-use token tracking with atomic SQLite WAL primary key constraints.	`Consumed Nonce Database (.db)`
SOC 2 CC6.8	Malicious Software & Obfuscated Code Defense	In-process AST gate with recursive base64 decoding (100% recall on 500 red-team vectors).	`100% Red-Team Attestation Dossier`
SOC 2 CC8.1	Authorized Change Management & Safe Commit	RFC 8785 Ed25519 verifiable PR security passports for automated autonomous code generation.	`Cryptographic PR Attestation Receipts`
HIPAA § 164.312(b)	Audit Controls & Cryptographic Integrity	Continuous Merkle tree hash-chaining of all intercepted actions and runtime verdicts.	`Signed SHA-256 Merkle Dossier`

The Partnership Structure: Mutual Asks & Mutual Wins

A high-velocity collaboration enabling Drata to lead the AI governance category while expanding Bartholomew's enterprise adoption.

WHAT WE OFFER DRATA

Immediate Product & Go-To-Market Value

- ✓ **First-to-Market AI Agent Governance:** Drata becomes the only automated compliance platform capable of continuously monitoring Cursor & Claude Code.
- ✓ **Pre-Built Native Integration:** Zero backend development required from Drata engineering; Bartholomew exports directly to Drata Evidence Locker API.
- ✓ **Enterprise Upsell Driver:** Enables Drata sales reps to unblock deals stalled by CISO fears over autonomous coding agents.
- ✓ **Verified Open-VSX Distribution:** Ready-to-deploy extensions with 14,000+ public downloads and sub-35µs performance.

WHAT WE REQUEST FROM DRATA

Partnership Support & Ecosystem Access

- ✓ **Drata Marketplace Listing:** Featured inclusion in the Drata Integration Directory under "AI Governance & Agent Security".
- ✓ **Auditor Acceptance Review:** Joint review with Drata's Audit Alliance (e.g. Schellman, Coalfire) to formally validate Bartholomew Merkle dossiers as continuous evidence.
- ✓ **Joint Design Partner Program:** Intro to 5 mutual enterprise customers piloting Cursor or Claude Code for a 30-day joint case study.
- ✓ **Co-Marketing Webinar:** Joint content campaign: *"How Regulated Engineering Teams Can Safely Deploy AI Coding Agents."*

30-Day Execution Roadmap

A rapid, low-overhead path to announce our integration and begin joint customer pilots.

DAYS 1 - 7

API Sandbox Sync

Test Bartholomew dossier export against Drata Evidence Locker sandbox API. Validate schema mapping and automated upload.

DAYS 8 - 14

Auditor Alignment

Present sample Merkle dossiers to Drata's auditor-partner network to confirm automated acceptance for SOC 2 Type II evidence.

DAYS 15 - 24

Joint Pilot (3 Cohorts)

Deploy Bartholomew across 3 Drata enterprise customers piloting Cursor. Verify zero-leakage and automated evidence capture.

DAYS 25 - 30

Public Launch

Publish Drata Marketplace integration, joint press release, and co-branded case study: "Air-Gapped Agent Governance".

Ready for Immediate Technical Demonstration

Full working CLI, SQLite replay store, and live demo script ready for evaluation today.

contact@bartholomew.info · bartholomew.info